MAJO BRIDGE TECHNOLOGIES AND EVENTS PLC

MaJo e-School Bridge (MayaBela) · INSA asset registration attachment

Technical Specifications (TDD / LLD)

Technical Design / Low-Level Design

Product: MaJo e-School Bridge (MayaBela)
Implementation-level detail for vulnerability identification and behaviour validation

Document number	MB-TDD-001
Version	1.0 · 10 November 2026 · East Africa Time (Africa/Nairobi)
INSA portal field	Technical Specifications (TDD / LLD) — provides implementation-level detail; used to identify technical vulnerabilities and validate system behaviour.
Companions	MB-SRS-001 (requirements) · MB-SDD-001 (architecture, trust boundaries)
Classification	CONFIDENTIAL — names functions and collections. No live passwords, PINs, or service-role values.

Paths below are in the submitted source. Hardened SQL (`20261105120000_insa_permission_hardening.sql`, `20261109120000_insa_driver_need_to_know.sql`) is CAAT-proven locally. Live project apply remains a notified window. This is not a pentest letter.

1. Persistence schema

School data is not one table per module. It is a document store:

```
public.app_documents (
  collection  text,     -- e.g. student_registry, grade_reports, fees
  school_id   text,     -- tenant; compared upper-case to jwt_school_id()
  doc_id      text,     -- row id inside the school
  data        jsonb,    -- payload
  primary key (collection, school_id, doc_id)
)
```

RLS is enabled. Anon has no policy on this table. Authenticated access is school-scoped and then role-scoped. Writes that use the Edge **service role** bypass RLS; those paths must call `guardRegistryRecord` (or an equivalent desk check) first.

2. Identity implementation

2.1 JWT claims

Helpers in `supabase/migrations/20260727210000_security_hardening.sql` (and later overlays) read **only** `auth.jwt() -> 'app_metadata'`:

Function	Claim	Vulnerability it closes
`jwt_school_id()`	`app_metadata.schoolId`	User cannot move tenant by writing `user_metadata`

Function	Claim	Vulnerability it closes
`jwt_role()`	`app_metadata.role`	Client cannot self-promote role in metadata
`jwt_username()`	`app_metadata.username`	Stable actor stamp for audit
`jwt_linked_driver_id()`	`app_metadata.linkedDriverId`	Driver need-to-know (INSA migration)

Login roles allowed by Edge: `admin | teacher | parent | driver | student` (`ROLES` in `supabase/functions/_shared/school_auth.ts`). Staff desks are extra keys on the teacher/admin JWT (`staffRoles` / permissions), not a sixth login role.

2.2 Secrets and rate limits

Mechanism	Implementation	Validate
School password	bcrypt, 12 rounds; `MIN_PASSWORD_LENGTH = 10`	Deno + login Edge
Login throttle	`LOGIN_RATE_LIMIT = 8` per 15 minutes per username+role+school	`school_auth.ts`
Platform PIN	PBKDF2-SHA256, 210,000 iterations; legacy `sha256:` verifies once then upgrades	`platform_pin_test.ts`
Owner PIN throttle	60 pre-verify checks / 15 min; 120 authed calls / 15 min after PIN	Must not share the school-login 8/15 cap
MFA TOTP	30 s window; recovery codes hashed. Required if `GoLiveService.isPrivilegedMfaRole` (admin JWT or accountant staff role)	`test/phase6_leadership_test.dart`
Anon key	Compiled into the client	`test/insa_client_key_test.dart` asserts service-role is absent

3. Authorisation algorithms

3.1 SELECT path

```
authenticated request
  → policy app_documents_select_school
       school_id = jwt_school_id()
       AND app_doc_readable(collection, doc_id, school_id, data)
  → if jwt_role() = 'driver':
       AND app_doc_driver_may_read(...)   -- own bus only for children / GPS
```

Source: `20261109120000_insa_driver_need_to_know.sql` (SELECT policy) plus `app_doc_readable` overlays. Driver function returns true immediately for non-drivers so teacher/admin/parent paths are unchanged.

3.2 Teacher write gate (SEC-001)

`app_doc_teacher_may_write` in `20261105120000_insa_permission_hardening.sql` runs **module gates before** any see-all shortcut:

- Always deny: `school_registry`, `platform_audit_log`.
- Safeguarding: student_affairs / VP / principal / full_access only; else false.
- Health / counselling / IEP / medication: student-affairs style roles or `manage_students`.
- Payroll / HR collections: denied to ordinary classroom teachers.

- Fees: paid-status fields require finance/cashier permission.
- Homework / attendance / grades: assigned class (and see-all only after these gates).

A 403 from RLS must not trigger a full-school client snapshot (`test/stale_write_storm_test.dart`).

3.3 DELETE

Delete policy requires the same school match plus readability / teacher-write where the migration states it. Parents, students, and drivers are not on the teacher delete path.

3.4 Service-role registry writes

`school-upsert-registry` uses the service role after JWT verify. SQL write-guard does not run. Substitute: `guardRegistryRecord` in `registry_write_policy.ts`.

Collection	Rule
`admission_applications`	`mayWriteAdmissions` → `manage_students` (registrar desk)
`exam_attempts`	Student may write only own `studentId`
Discipline desk fields	Status/outcome only by student-affairs (or escalation desk), not the reporter

CI: `deno test --allow-read … registry_write_policy_test.ts`.

4. Driver need-to-know (LLD)

`app_doc_driver_bus_id()` looks up `driver_registry` in the JWT school by linked driver id, `driverId`, or `loginUsername`, and returns `busId`.

`app_doc_driver_may_read` for role `driver`:

- `student_registry`: allow iff student's `transportId` equals that bus. Walkers and other buses: deny.
- `bus_live_positions` / scans / passenger status: own bus / own driver id.
- Notices / conversations / bus catalogue: school-scoped only (no extra child dump).

Write trigger: driver may stamp own id on own-bus GPS/scans; foreign-bus overwrite refused. CAAT: `11_insa_driver_need_to_know.sql` (9/9).

5. Storage implementation

Bucket	Policy idea	Client path
`school-branding`	Public SELECT; logos/stamps only	Login has no JWT
`school-files`	Authenticated; object name under `schools/<JWT school>/`	Photos, documents

Setup probe (must not be a shared prefix): `schools/<SCHOOLID>/_app_setup_probe/<timestamp>.txt` in `lib/database/supabase/supabase_storage_bootstrap.dart`. Probe is skipped unless signed-in **and** JWT school id is non-empty.

6. Edge Function technical catalogue

Inventory: `supabase/functions/_shared/edge_auth_inventory.ts` (25 functions). Test fails if a directory is missing an auth mode.

Mode	Technical check	Main vulnerability if missing
password-login	bcrypt + 8/15 min	Online guessing
user-jwt	Verify caller JWT; school from claims	Cross-tenant write via service role
platform-owner-pin	PBKDF2 + separate rate cap	Owner console brute force; must not share login cap
public-rate-limited	No JWT; no existence leak on reset	User enumeration; intake flood
push-secret	`x-push-secret`; body re-read from stored notification	Forged push content

Maya Assistant: JWT required; live context is counts only; system instruction refuses health, safeguarding, passwords, children's IDs. Missing `MAYA_AI_API_KEY` → HTTP 412; SIS still runs.

7. Client technical constraints

- Connect only to configured `SUPABASE_URL` over HTTPS. Empty GitHub secrets must not dart-define blank URL/key (that wipes compiled defaults and breaks Admin login on Pages).
- Pages headers: HSTS, CSP, `X-Frame-Options: DENY`, nosniff (`web/_headers`).
- Privileged MFA prompt: `GoLiveService.isPrivilegedMfaRole` — `roleAdmin` or `StaffRoles.accountant` (includes titled finance copies). Teachers/principals remain opt-in.

8. Behaviour validation (CAAT / CI)

Suite	What it proves	Does not prove
`10_insa_permission_hardening.sql`	Teacher denied payroll/HR; fees paid-status; grade audit append-only; homework class-bound; audit actor stamp	Live hosted project already has the migration
`11_insa_driver_need_to_know.sql`	9/9 own-bus vs other-bus / walker / GPS	Live apply
`12_insa_two_school_isolation.sql`	7/7 SCH1 vs SCH2	Live two-school PostgREST (optional staging job)
Flutter unit tests	MFA privileged set; 403 does not dump school; anon vs service-role in client	Network attacker on production
Deno inventory + registry + PIN tests	25 functions catalogued; admissions registrar-only; PIN hash format	INSA-certified pentest

Production project `hwkiihonthueadbhcvfi` is refused as an RLS isolation target in `tools/test_rls_isolation.mjs`.

9. Technical vulnerabilities (for INSA review)

These are identified from the implementation, not hidden. Severity is for the submitted design.

ID	Issue	Layer	Status
TV-01	Anon/publishable key in the binary	Client	Accepted; RLS is the boundary. Service-role grepped out of Dart.
TV-02	Teacher MFA optional	Auth	Accepted for classroom availability; Admin+Finance required.
TV-03	Public branding bucket	Storage	Required for login-without-JWT. Mis-upload of student files is a spill (IRP).
TV-04	Service-role Edge bypass of RLS	API	Mitigated by inventory + `guardRegistryRecord`. A new function without a mode fails CI.
TV-05	Stolen staff JWT until expiry	Session	HTTPS + MFA on privileged desks. Shared teacher PCs remain a residual.
TV-06	Hosted disk keys not MaJo-held	Supplier	CMCSRS §6.29.f residual; not fixable in Flutter.
TV-07	Live SQL may lag source	Change	Documented; staging then notified window. CAAT is on source.
TV-08	Optional AI prompt may contain a name	TB-7	Counts-only automatic context; instruction refuses PII/safeguarding.
TV-09	No independent pentest letter yet	Assurance	Scheduled after staging apply (CSMS-TEV-001).

10. Traceability

SRS / SDD	LLD artefact
FR-01 / SR-04 / TB-2	`jwt_school_id` / `jwt_role` / school-login
FR-03 / SR-02	`app_doc_teacher_may_write`
FR-07 / SR-03 / TB-4	`app_doc_driver_may_read` + write trigger
FR-05 / AS-07	`mayWriteAdmissions`
FR-11 / TB-5 / AS-05	`school-branding` vs `school-files` prefix
SR-06	`isPrivilegedMfaRole`
SR-12	CAAT 10/11/12 + Deno + Flutter tests

Prepared by (Engineering / CSO)

Majo Bridge Technologies and Events PLC · 10 November 2026, East Africa Time

For INSA asset registration

Attachment to field: Technical Specifications (TDD / LLD)

Restricted. Not a gazetted INSA certificate and not a third-party pentest report.